Fliegen, wenn die Systeme ausfallen

Was Cyber-Resilienz von der Luftfahrt lernen kann – und was nicht

Handout zur Antrittsvorlesung von Prof. Dr. Dirk Loomans, Hochschule Mainz, Fachbereich Wirtschaft, 12. November 2026 · dirk.loomans@hs-mainz.de

> Kernaussage
>
> Cybersicherheit will Ausfälle verhindern, Resilienz heißt: trotz Ausfall weiterarbeiten. Die Luftfahrt hat dafür vier Prinzipien entwickelt, die sich auf die IT übertragen lassen – mit Grenzen, die man kennen sollte.

Ausgangslage: 19. Juli 2024

Ein fehlerhaftes Update der Sicherheitssoftware CrowdStrike Falcon legte nach Schätzung von Microsoft rund 8,5 Millionen Windows-Rechner lahm. Flughäfen, Banken und Kliniken standen still, in Indien wurden Bordkarten von Hand geschrieben. Kein Flugzeug hatte an diesem Tag ein technisches Problem. Ausgefallen ist alles drumherum: Check-in, Crew-Planung, Gepäck, Anzeigetafeln.

Vier Prinzipien aus der Luftfahrt

1. Design für Menschen: das Rad am Hebel

Im Zweiten Weltkrieg fuhren Piloten der B-17 nach der Landung immer wieder das Fahrwerk statt der Landeklappen ein. Die Schalter sahen gleich aus und lagen nebeneinander. Der Psychologe Alphonse Chapanis erkannte darin keinen Pilotenfehler, sondern einen Konstruktionsfehler. Seine Lösung war Form: ein Rad am Fahrwerkshebel, ein Keil an den Landeklappen. Diese Formen sind bis heute vorgeschrieben (14 CFR § 25.781).

Die Software-Welt baut die gleichen Schalter noch immer. In Hawaii lagen 2018 Übung und Ernstfall des Raketenalarms als fast gleich lautende Einträge im selben Menü; die Rückfrage „Are you sure?“ hat den Fehlalarm nicht verhindert. Bei der Citibank sollten 2020 rund 7,8 Millionen Dollar Zinsen überwiesen werden – wegen einer unübersichtlichen Eingabemaske gingen fast 900 Millionen Dollar hinaus, obwohl drei Personen geprüft hatten. *Eine Sicherheitsabfrage ist kein Rad am Hebel.*

2. Lernen statt Schuld

Die IT fragt oft: *Wer hat geklickt?* Die Luftfahrt fragt: *Was hat ihn klicken lassen?* Unfalluntersuchungen dienen nach ICAO Annex 13 ausdrücklich nicht der Schuldzuweisung. Die Verordnung (EU) Nr. 376/2014 verankert die *Just Culture*: Wer einen Fehler meldet, wird dafür nicht bestraft, solange weder Vorsatz noch grobe Fahrlässigkeit vorliegen. Wo Fehler bestraft werden, werden sie versteckt und wiederholt; wo sie offen analysiert werden, entstehen Leitplanken.

3. Automation mit Rückfallebene

Schon 1997 warnte ein Ausbilder von American Airlines vor den *Children of the Magenta*: Piloten, die dem Bordcomputer folgen, statt das Flugzeug zu führen. Beim Absturz von Air France 447 im Juni 2009 vereisten die Geschwindigkeitssonden, der Autopilot schaltete ab, und die Besatzung fand nicht mehr in die Handsteuerung zurück; 228 Menschen starben. Der Austausch der bekanntermaßen schwachen Sonden hatte zwei Tage zuvor begonnen, verpflichtend war er nicht. Für Organisationen, die Routine an KI-Agenten übergeben, lautet die Frage: *Wer fliegt von Hand, wenn der Agent abschaltet – und wann wurde das zuletzt geübt?*

4. Redundanz und geordneter Rückbau

Nach einem Vogelschlag blieben der Besatzung von US Airways 1549 im Januar 2009 rund 208 Sekunden bis zur Wasserung auf dem Hudson. Die Checkliste war für einen Triebwerksausfall in großer Höhe geschrieben; geholfen haben Training und Urteilskraft. *Im Notfall fällt man nicht auf das Niveau der Dokumentation zurück, sondern auf das Niveau der Übung*.

Der A320 selbst fällt nicht aus, er fällt zurück: Fünf Flugsteuerungsrechner unterschiedlicher Bauart schalten bei Fehlern stufenweise von Normal Law über Alternate und Direct Law bis zur mechanischen Rückfallebene. Die IT dagegen verteilt denselben Sicherheitsagenten mit demselben Update auf alle Rechner. Bei Maersk zerstörte NotPetya 2017 alle Domain Controller weltweit; gerettet hat ein einziger Server in Ghana, der wegen eines Stromausfalls offline war. Das war kein Notfallplan, sondern Glück.

Wo der Vergleich hinkt

- **Das Gewitter lernt nicht mit.** Angreifer passen sich an und lesen veröffentlichte Notfallverfahren mit.
- **Eine Zulassung dauert Jahre, ein Exploit Stunden.** Zertifizierung friert Software ein, Sicherheit verlangt Updates.
- **Redundanz rechnet mit Zufall, ein Angreifer nicht.** Er trifft alle Kopien gleichzeitig.
- **Auch die Luftfahrt vergisst ihre Regeln.** Bei der Boeing 737 MAX hing das MCAS an einem einzigen Sensor, und die Aufsicht hatte laut Joint Authorities Technical Review (2019) zu wenig Einblick.

Umgekehrt lernt die Luftfahrt jetzt von der IT: Mit „Part-IS“ brauchen Airlines, Instandhaltung und Flugsicherung seit Februar 2026 ein Managementsystem für Informationssicherheit.

Der Cyber Resilience Act

Die Verordnung (EU) 2024/2847 überträgt einen Grundgedanken der Lufttüchtigkeit auf digitale Produkte: Pflichten über den ganzen Lebenszyklus. Seit dem 11. September 2026 müssen Hersteller aktiv ausgenutzte Schwachstellen und schwere Sicherheitsvorfälle melden; ab dem 11. Dezember 2027 gilt die CE-Kennzeichnung nach dem CRA mit Updates, Schwachstellenmanagement und Software-Stückliste (SBOM). Anders als in der Luftfahrt genügt für die meisten Produkte eine Selbstbewertung des Herstellers. Auch die Luftfahrt delegiert Prüfungen – entscheidend ist die Aufsicht.

Vier Thesen

1. Nicht der Mensch ist die Schwachstelle, sondern der Hebel, der aussieht wie der andere.
2. Wer nicht mehr von Hand fliegen kann, darf den Autopiloten nicht einschalten.
3. Hundert Kopien desselben Systems sind keine Redundanz, sondern ein Klumpenrisiko.
4. Die Luftfahrt kämpft gegen das Wetter. Wir kämpfen gegen jemanden, der mitliest.

Fragen für Ihre Organisation

- Wo sehen eine harmlose und eine folgenschwere Aktion in Ihren Systemen gleich aus?
- Fragen Sie nach einem Vorfall zuerst „Wer?“ oder „Was?“ – und wird ein falscher Klick ohne Angst gemeldet?
- Welche Abläufe könnten Sie einen Tag lang mit Stift und Papier weiterführen – und wann wurde das zuletzt geübt?
- Wie viele Ihrer Systeme hängen an demselben Hersteller, demselben Agenten, demselben Update?

Quellen

- BEA (2012): Final Report on the accident on 1st June 2009, Airbus A330-203, Flight AF 447.
- Federal Aviation Administration: 14 CFR § 25.781, Cockpit control knob shape.
- FCC (2018): Report on the January 13, 2018 False Ballistic Missile Alert.
- Greenberg, A. (2018): The Untold Story of NotPetya, the Most Devastating Cyberattack in History. *WIRED*.
- In re Citibank August 11, 2020 Wire Transfers, S.D.N.Y. 2021; aufgehoben durch 2nd Circuit, 2022.
- Joint Authorities Technical Review (2019): Boeing 737 MAX Flight Control System.
- Microsoft (D. Weston, 20.07.2024): Helping our customers through the CrowdStrike outage.
- NTSB (2010): AAR-10/03, Loss of Thrust in Both Engines, US Airways Flight 1549.
- UX Magazine: *Pilot Error, Chapanis and the Shape of Things to Come*.
- VO (EU) 376/2014; 2022/1645 und 2023/203 (Part-IS); 2024/2847 (CRA).